PAI-2 · BYODSEC

Universidad Pública U-Secure · Road Warrior VPN TLS · Memoria técnico-metodológica

Estado del documento: borrador de entrega, completar evidencias experimentales realizadas en WSL2/Windows. No sustituye la revisión final del grupo.

1. Resumen de la solución

Se ha diseñado una solución de acceso remoto con aplicación BYODSEC en Python/FastAPI, autenticación mutua TLS 1.3 mediante certificados X.509, cuentas y emparejamientos persistidos en SQLite y una integración administrativa HTTPS/REST con OpenVPN Access Server 3.2 o superior. El transporte de paquetes se realiza por OpenVPN; la gestión de sesiones y autorizaciones se realiza por REST.

La API de registro (RF1) está separada del gateway mTLS porque, antes de registrar un dispositivo, el cliente todavía no dispone de certificado. En RF2 se comprueban el certificado negociado, la asociación dispositivo-usuario, una prueba de posesión de clave, la contraseña y un desafío de un solo uso. En RF4 se bloquea la reconexión, se ordena la desconexión VPN y se invalidan sesiones SQLite.

2. Arquitectura y límites

Cliente Windows: aplicación de consola, certificado X.509 del dispositivo, cliente OpenVPN propio. Gateway FastAPI: HTTPS/mTLS y validación de usuario en SQLite. Servidor Linux WSL2: OpenVPN Access Server con API REST protegida. La interfaz REST de administración no se expone a usuarios finales.

La CA corporativa BYODSEC, el certificado HTTPS web de Access Server y la PKI VPN de Access Server pueden ser distintos. Se exige verificar su confianza, mapear sus identidades y documentar la distribución de los certificados. Esta correspondencia debe acreditarse en el despliegue final.

3. Política de seguridad

TLS 1.3, autenticación bidireccional en el gateway, algoritmos AEAD y PFS, denegación predeterminada de cuentas VPN, cuentas no administrativas, ausencia de perfiles autologin, contraseñas protegidas mediante scrypt y tokens opacos almacenados únicamente por hash. Las claves privadas, contraseñas y ficheros SQLite reales no se incluyen en el ZIP.

4. Requisitos funcionales y trazabilidad

Requisito	Implementación y evidencia
RF1 · Registro / emparejamiento	src/server/app.py y SQLite users/device_pairings; test_rf1_registration.py. Reemisión/revocación debe validarse con evidencia.
RF2 · Inicio de sesión mTLS + credenciales	src/rf2, src/gateway; tests RF2 y test de red real TLS1.3/mTLS.
RF4 · Cierre y túnel	src/vpn_rest_as/rf4.py: deny por REST, disconnect por REST, invalidación en SQLite. Prueba aislada superada; prueba con VPN real pendiente.
RF5 · Usuarios / roles	src/rf5, precarga de PDI/PAS/Investigadores y certificados X.509. La sincronización de cuentas Access Server es una operación separada.

5. Requisitos de seguridad

Requisito	Demostración y situación
RS1 PKI/mTLS	PKI corporativa BYODSEC y mTLS probados localmente. Pendiente comprobar PKI de clientes OpenVPN y vinculación estricta entre identidades.
RS2 TLS 1.3 / AEAD / PFS	Script de configuración TLS 1.3 y tests negativos de TLS1.2. Falta registrar el conjunto concreto de cipher suites negociadas en el túnel real.
RS3 300 concurrentes	Scripts comparativos iperf3 incluidos. No se ha medido 300 túneles reales: la edición gratuita Access Server limita a 2 conexiones.
RS4 .pcap / trazabilidad	Scripts tcpdump, logs de aplicación y guía Wireshark. Pendiente aportar archivos .pcap y auditorías del entorno del usuario.

6. Endpoints principales

POST /api/v1/devices/register · POST /api/v1/sessions/challenge · POST /api/v1/sessions/login · GET /api/v1/sessions/me · POST /api/v1/vpn/authorize · GET /api/v1/vpn/me · POST /api/v1/sessions/logout.

7. Manual de despliegue resumido

1) Instalar Python y dependencias del repositorio. 2) Crear y proteger la CA local, emitir certificados de servidor y dispositivos. 3) Verificar RF5 y perfiles corporativos en SQLite. 4) Instalar Access Server 3.2+ en Ubuntu WSL2 y aplicar TLS 1.3. 5) Crear cuentas VPN individuales inicialmente denegadas y sin perfiles de inicio automático. 6) Configurar BYODSEC_AS_URL, BYODSEC_AS_CA_BUNDLE y credenciales administrativas fuera del repositorio. 7) Iniciar el gateway mTLS alternativo y la consola BYODSEC. 8) Autenticar RF2, habilitar la VPN mediante REST, conectar el cliente OpenVPN, comprobar red interna y ejecutar RF4.

Para comandos exactos y pasos entre equipos, consultar docs/PLAN_CUMPLIMIENTO_COMPLETO.md. El campo de verificación TLS/PKI nunca debe desactivarse para evitar problemas de certificado.

8. Pruebas de seguridad y extra opcional (+10 %)

El ensayo opcional ejecuta tres situaciones únicamente sobre localhost con certificados efímeros: (a) servidor impostor con CA desconocida; (b) conexión cliente sin certificado mTLS; (c) cliente forzado a TLS 1.2. El sistema rechaza las negociaciones inseguras; el script registra un JSON reproducible en evidencias/ataques/tls_opcional.json. Para acreditar plenamente la resistencia del túnel deben añadirse capturas del entorno real y una prueba de rechazo de reconexión tras RF4.

9. Pruebas de rendimiento planificadas

Usuarios VPN	Conexiones reales	RTT (ms)	Throughput (Mbps)	CPU/RAM
10	Pendiente	Pendiente	Pendiente	Pendiente
50	Pendiente	Pendiente	Pendiente	Pendiente
100	Pendiente	Pendiente	Pendiente	Pendiente
200	Pendiente	Pendiente	Pendiente	Pendiente
300	Pendiente	Pendiente	Pendiente	Pendiente

Para la comparación directa/VPN mantener idénticos nodos y carga, medir iperf3 y ping, y registrar CPU/RAM en WSL. No confundir 300 cuentas creadas con 300 VPN concurrentes.

10. Evidencias y validación final

Evidencias previstas: capturas en Wireshark de TLS1.3 y tramas cifradas, rechazo de certificado no reconocido, conexión VPN autorizada, revocación de sesión en SQLite, caída de túnel después de logout y rechazo de reconexión sin un nuevo RF2. Guardar timestamps y logs sin claves, tokens ni contraseñas.

11. Riesgos y trabajo pendiente

La instalación de Access Server está en WSL2, con limitaciones de red y capacidad. Es necesaria licencia o solución alternativa para los 300 usuarios. Existe un desacoplamiento entre la PKI BYODSEC y la PKI VPN, que debe cerrarse o justificarse técnicamente. Para una implementación de producción se requeriría custodia robusta de CA, renovación, revocación y auditoría centralizada.

Si en la validación real aparece un fallo de desconexión por REST, el cierre de aplicación invalida los tokens, pero no debe declararse completado el RF4 mientras un túnel permanezca abierto. En ese caso el sistema responde con error, registra el problema y obliga a revisión.

12. Criterios de entrega

Entregar PAI2-STX.zip con código, tests, configuraciones reproducibles y evidencias depuradas. Adjuntar este PDF revisado, sin superar 15 páginas. Verificar instalación en un equipo limpio y reflejar explícitamente cualquier requisito no satisfecho. Fecha indicada en el enunciado: 27 de octubre a las 23:59.

Documento preparado como borrador técnico: sustituir resultados pendientes únicamente cuando existan registros/capturas medidos.